

ПРАКТИЧЕСКАЯ РАБОТА № 16.2

Тема: Iptables, WEB APPLICATION FIREWALL

Программное обеспечение:

- | | | | | | |
|----|-----|-------|----|--------|---|
| 1. | ISO | образ | ОС | CentOS | 7 |
|----|-----|-------|----|--------|---|

https://buildlogs.centos.org/rolling/7/isos/x86_64/ или

ISO образ ОС Ubuntu 16.04 <https://releases.ubuntu.com/16.04/>

Вопросы для обсуждения:

1. Что такое межсетевой экран?
2. Для чего используется межсетевой экран?
3. Принцип работы Netfilter.
4. Таблицы межсетевого экрана Netfilter. Для чего они используются?
5. Что такое правила межсетевого экрана?
6. Как создавать правила для межсетевого экрана утилитой Iptables?
7. Как сохранить правила для последующей автозагрузки?
8. Что такое Web Application Firewall?
9. Как настроить правила в WAF mod_security?

Цель: Изучение межсетевых экранов. Приобретение навыков работы с Iptables и WAF.

Основные теоретические сведения

Межсетевой экран

Скорее всего, ранее вы уже сталкивались с таким понятием как межсетевой экран. В ядро Linux встроен свой межсетевой экран, называемый Netfilter. Управление им осуществляется с помощью утилиты Iptables.

Межсетевой экран, сетевой экран, файервол, брандмауэр — комплекс аппаратных или программных средств, осуществляющий контроль и фильтрацию проходящих через него сетевых пакетов в соответствии с заданными правилами. Основной задачей сетевого экрана является защита

компьютерных сетей или отдельных узлов от несанкционированного доступа. Также сетевые экраны часто называют фильтрами, так как их основная задача — не пропускать (фильтровать) пакеты, не подходящие под критерии, определённые в конфигурации.

Рассмотрим принцип работы Netfilter. Когда сетевые пакеты попадают в сетевой интерфейс, они после ряда проверок ядром проходят последовательность так называемых цепочек. Пакет обязательно проходит через цепочку PREROUTING, после чего определяется, кому он, собственно, был адресован. Если пакет не адресован локальной системе (в нашем случае серверу), он попадает в цепочка FORWARD, а иначе — в цепочку INPUT, после прохождения которой отдается локальным демонам или процессам. После этого при необходимости формируется ответ, который направляется в цепочку OUTPUT. После цепочек OUTPUT или FORWARD пакет в очередной раз встречается с правилами маршрутизации и направляется в цепочку POSTROUTING. В результате прохождения пакетом цепочек фильтрации несколько раз, проверка его принадлежности определенным критериям осуществляется несколько раз. В соответствии с этими проверками к пакету применяется определенное действие:

- ACCEPT — пакет «принимается» и передается в следующую цепочку.
- DROP — удовлетворяющий условию пакет отбрасывается и не передается в другие таблицы или цепочки.
- REJECT — пакет отбрасывается, но при этом отправителю отправляется ICMP-сообщение, сообщающее об отказе.
- RETURN — пакет возвращается в предыдущую цепочку и продолжает её прохождение начиная со следующего правила
- SNAT — применить трансляцию источника в пакете. Используется только в цепочках POSTROUTING и OUTPUT таблицы nat.

– DNAT — применить трансляцию адреса назначения в пакете. Используется в цепочках PREROUTING и (очень редко) OUTPUT в таблице nat.

Основные команды Iptables

– **append (-A)** Позволяет добавить в указанную цепочку и таблицу заданное правило, помещаемое в КОНЕЦ списка `iptables -A FORWARD` критерии -j действие

– **delete (-D)** Позволяет удалить заданное номером или каким-либо правилом правило. В первом примере удаляются все правила с номерами 10,12 во всех цепочках, в таблицах filter. `iptables -D 10,12` `iptables -t mangle -D PREROUTING` критерии -j действие

– **rename-chain (-E)** Изменить имя цепочки. `iptables -E OLD_CHAIN NEW_CHAIN`

– **flush (-F)** Очищает все правила текущей таблицы. Ко всем пакетам, относящимся к уже установленным соединениям, применяется терминальное действие ACCEPT — пропустить `iptables -F`

– **insert (-I)** Добавляет заданное правило в соответствии с номером. `iptables -I FORWARD 5` критерии -j действие

– **list (-L)** Позволяет просматривать существующие правила (без явного указания таблицы - отображается таблица filter всех цепочек). `iptables -L`

– **policy (-P)** Позволяет устанавливать стандартную политику для заданной цепочки. `iptables -t mangle -P PREROUTING DROP`

– **replace (-R)** Заменяет заданное номером правило на заданное в критериях. `iptables -R POSTROUTING 7 |` критерии -j действие

– **delete-chain (-X)** Удалить ВСЕ созданные вручную цепочки (оставить только стандартные INPUT, OUTPUT...) `iptables -X`

– **zero (-Z)** Обнуляет счетчики переданных данных в цепочке. `iptables -Z INPUT`

- `line-numbers` Указывать номера правил при выводе (может использоваться совместно с `-L`). `iptables -L -line-numbers`
- `help (-h)` Помощь `Iptables -help`
- `t` таблица задает название таблицы, над которой необходимо совершить действие. В примере сбрасывается таблица `nat` во всех цепочках.
`iptables -t nat -F`
- `verbose (-v)` Детальный вывод. `iptables -L -v`

Основные правила отбора пакетов

- `protocol(сокр. -p)` Определяет протокол транспортного уровня. Опции `tcp`, `udp`, `icmp`, `all` или любой другой протокол определенный в `/etc/protocols` `iptables -A INPUT -p tcp`
- `source (-s, -src)` IP адрес источника пакета. Может быть определен несколькими путями: Одиночный хост: `host.domain.tld`, или IP адрес: `10.10.10.3` Пул-адресов (подсеть): `10.10.10.3/24` или `10.10.10.3/255.255.255.0`
`iptables -A INPUT -s 10.10.10.3`
- `destination(-d)` IP адрес назначения пакета. Может быть определен несколькими путями (см. `-source`). `iptables -A INPUT -destination 192.168.1.0/24`
- `in-interface (-i)` Определяет интерфейс, на который прибыл пакет. Полезно для NAT и машин с несколькими сетевыми интерфейсами. Применяется в цепочках `INPUT`, `FORWARD` и `PREROUTING`. Возможно использование знака `+`, тогда подразумевается использование всех интерфейсов, начинающихся на имя+ (например `eth+` - все интерфейсы `eth`).
`iptables -t nat -A PREROUTING -in-interface eth0`
- `out-interface(-o)` Определяет интерфейс, с которого уйдет пакет. Полезно для NAT и машин с несколькими сетевыми интерфейсами. Применяется в цепочках `OUTPUT`, `FORWARD` и `POSTROUTING`. Возможно использование знака `+`. `iptables -t nat -A POSTROUTING -in-interface eth1`

Неявные (необщие) параметры

- `p proto -h` Вывод справки по неявным параметрам протокола `proto`. `iptables -p icmp -h`
- `source-port(-sport)` Порт источник, возможно только для протоколов `-protocol tcp`, или `-protocol udp` `iptables -A INPUT -protocol tcp -source-port 25`
- `destination-port(-dport)` Порт назначения, возможно только для протоколов `-protocol tcp`, или `-protocol udp` `iptables -A INPUT -protocol udp -destination-port 67`

Явные параметры

- `m state -state` (устарел) он же `-m conntrack -ctstate` Состояние соединения. Доступные опции: NEW (Все пакеты, устанавливающие новое соединение) ESTABLISHED (Все пакеты, принадлежащие установленному соединению) RELATED (Пакеты, не принадлежащие установленному соединению, но связанные с ним. Например - FTP в активном режиме использует разные соединения для передачи данных. Эти соединения связаны.) INVALID (Пакеты, которые не могут быть по тем или иным причинам идентифицированы). `iptables -A INPUT -m state -state NEW, ESTABLISHED` `iptables -A INPUT -m conntrack -ctstate NEW, ESTABLISHED`
- `m mac -mac-source` Задаёт MAC адрес сетевого узла, передавшего пакет. MAC адрес должен указываться в форме `XX:XX:XX:XX:XX:XX`. `-m mac -mac-source 00:00:00:00:00:0`

Дополнительные параметры

DNAT (Destination Network Address Translation)

- `to-destination` Указывает, какой IP адрес должен быть подставлен в качестве адреса места назначения. В примере во всех пакетах протокола `tcp`, пришедших на адрес `1.2.3.4`, данный адрес будет заменен на

4.3.2.1. `iptables -t nat -A PREROUTING -p tcp -d 1.2.3.4 -j DNAT -to-destination 4.3.2.1`

LOG

- `log-level` используется для задания уровня журналирования (log level). В примере установлен максимальный уровень логирования для всех tcp пакетов в таблице filter цепочки FORWARD. `iptables -A FORWARD -p tcp -j LOG --log-level debug`

- `log-prefix` задает текст (префикс), которым будут предваряться все сообщения iptables. Префикс может содержать до 29 символов, включая и пробелы. В примере отправляются в syslog все tcp пакеты в таблице filter цепочки INPUT с префиксом INRUT-filter. `iptables -A INPUT -p tcp -j LOG --log-prefix INRUT-filter`

- `log-ip-options` Позволяет заносить в системный журнал различные сведения из заголовка IP пакета. `iptables -A FORWARD -p tcp -j LOG --log-ipoptions`

в скобках – сокращенный вариант записи

Основные цепочки межсетевого экрана Netfilter:

- PREROUTING — изначальная обработка входящих пакетов
- INPUT — для входящих пакетов, адресованных непосредственно локальному компьютеру
- FORWARD — для маршрутизируемых пакетов
- OUTPUT — для пакетов, исходящих с локального компьютера
- POSTROUTING — для окончательной обработки исходящих пакетов

Таблицы межсетевого экрана Netfilter:

- raw - используется для маркировки пакетов, которые не должны обрабатываться системой определения состояний. Содержится в цепочках PREROUTING и OUTPUT.

- mangle — содержит правила модификации IP-пакетов.

- nat - предназначена для подмены адреса отправителя или получателя. Данную таблицу проходят только первые пакеты из потока - трансляция адресов или маскировка (подмена адреса отправителя или получателя) применяются ко всем последующим пакетам в потоке автоматически. Поддерживает действия DNAT, SNAT, MASQUERADE, REDIRECT. Содержится в цепочках PREROUTING, OUTPUT, и POSTROUTING.

- filter — основная таблица, используется по умолчанию если название таблицы не указано. Используется для фильтрации пакетов. Содержится в цепочках INPUT, FORWARD, и OUTPUT.

Пример создания правила для межсетевого экрана

Рассмотрим две цепочки, задающие два основных правила Iptables — PREROUTING и FORWARD.

- iptables -t nat -A PREROUTING -i eth0 -j DNAT --to-destination 192.168.57.102

- iptables -A FORWARD -d 192.168.57.102 -j ACCEPT

Первая из них определяет первоначальную обработку всех пакетов, приходящих на адаптер eth0:

- -t определяет подключаемую таблицу, в данном случае — nat — для подмены адреса отправителя или получателя

- -A — выбор цепочки

- -i — входящий интерфейс

- -j — действие с пакетами, удовлетворяющими условию — в данном случае DNAT — подмена адреса получателя

- -to-destination — выбор адреса, на который перенаправляются пакеты

Вторая определяет проброс пакетов через сервер:

- -A — выбор цепочки
- -d — выбор адресата
- -j — выбор действия

Web Application Firewall

WAF (Web Application Firewall) — это межсетевые экраны, работающие на прикладном уровне и осуществляющие фильтрацию трафика Web-приложений. Эти средства не требуют изменений в исходном коде Web-приложения и, как правило, защищают Web-сервисы гораздо лучше обычных межсетевых экранов и средств обнаружения вторжений.

Основные преимущества:

- Анализ поведения пользователя в используемом приложении;
- Позволяет осуществлять мониторинг HTTP трафика и проводить анализ событий в реальном режиме времени;
- Предотвращение вредоносных запросов;
- Распознавание большинства опасных угроз;
- Дополнение сетевых средств безопасности;
- Просматривать детальные отчеты об атаках и попытках взлома.

Задание к практической работе

Часть 1

- Установите web-сервер `<sudo apt-get install apache2>`
- Просмотрите список текущих правил iptables таблицы filter

`sudo iptables -L`

- Вы увидите, что список содержит три цепочки по умолчанию (INPUT, OUTPUT и FORWARD), в каждой из которых установлена политика по умолчанию (на данный момент это ACCEPT).

- С помощью команды `<sudo iptables -S>` данный список можно просмотреть в другом формате, который отражает команды, необходимые для активации правил и политик.

- Чтобы сбросить текущие правила (если таковые есть), наберите:

- `sudo iptables -F`

- Цепочка INPUT отвечает за входящий трафик.

- Чтобы внести локальный интерфейс выполните:

- `sudo iptables -A INPUT -i lo -j ACCEPT`

- Чтобы заблокировать весь исходящий трафик, кроме портов для SSH и веб-сервера, нужно сначала разрешить подключения к этим портам. В цепочку ACCEPT добавьте два порта (порт SSH 22 и порт http 80), что разрешит трафик на эти порты.

- `sudo iptables -A INPUT -p tcp -m tcp --dport 22 -j ACCEPT`

- `sudo iptables -A INPUT -p tcp -m tcp --dport 80 -j ACCEPT`

- В данной работе мы не используем SSH. Так что удалим ненужное правило. Для этого:

- `sudo iptables -D INPUT -p tcp -m tcp --dport 22 -j ACCEPT`

- Нужно добавить еще одно правило, которое позволит устанавливать исходящие соединения (т.е. использовать ping или запускать обновления программного обеспечения):

```
sudo iptables -I INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

– Создав все эти правила, можно заблокировать все остальное и разрешить все исходящие соединения.

```
sudo iptables -P OUTPUT ACCEPT
```

```
sudo iptables -P INPUT DROP
```

– Просмотрите список правил

```
sudo iptables -L
```

– Добавим еще несколько правил для блокировки наиболее распространенных атак. Для начала нужно заблокировать нулевые пакеты <sudo iptables -A INPUT -p tcp --tcp-flags ALL NONE -j DROP>.

– Следующее правило отражает атаки syn-flood <sudo iptables -A INPUT -p tcp ! --syn -m state --state NEW -j DROP>. Теперь фаервол не будет принимать входящих пакетов с tcp-флагами. Нулевые пакеты, по сути, разведывательные. они используются, чтобы выяснить настройки сервера и определить его слабые места.

– Далее нужно защитить сервер от разведывательных пакетов XMAS <sudo iptables -A INPUT -p tcp --tcp-flags ALL ALL -j DROP>. Теперь сервер защищен от некоторых общих атак, которые ищут его уязвимости.

– Со второй виртуальной машины, на которую установите nmap, проведите XMAS сканирование <sudo nmap -sX>.

– По умолчанию все не сохраненные правила действуют до следующей перезагрузки сервера; сразу же после перезагрузки не сохраненные правила будут потеряны. Самый простой способ загрузить пакет iptables-persistent <sudo apt-get install iptables-persistent>. Во время инсталляции пакет уточнит, нужно ли сохранить текущие правила для

дальнейшей автоматической загрузки, если текущие правила были протестированы и соответствуют всем требованиям, их можно сохранить.

Часть 2

- Для начала понадобится LAMP (Apache, MySQL, PHP). В практической работе № 4.2, уже было показано, как установить его, используя tasksel.

- Установите mod_security <sudo apt-get install libapache2-mod-security2>

- Выполните команду <sudo apachectl -M | grep -color security2>. Если на экране появился модуль по имени security2_module (shared), значит, все прошло успешно.

- В каталоге логов Apache можно найти новый лог-файл для mod_security. /var/log/apache2/modsec_audit.log

- Установка ModSecurity включает в себя конфигурационный файл, который нужно переименовать: <sudo mv /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf>.

- Затем перезапустите Apache <sudo service apache2 reload>.

- Стандартный конфигурационный файл настроен на DetectionOnly, то есть, фаервол только отслеживает логи, при этом ничего не блокируя. Чтобы изменить это поведение, отредактируйте файл modsecurity.conf: <sudo nano /etc/modsecurity/modsecurity.conf>

- Найдите в файле строку: «SecRuleEngine DetectionOnly». И измените ее так: «SecRuleEngine On».

- Найдите «SecResponseBodyAccess On» и замените на «SecResponseBodyAccess Off». Эта директива отвечает за буферизацию тела ответа; ее рекомендуется включать, только если требуется обнаружение и предохранение от утечки данных. Включенная директива (SecResponseBodyAccess On) не только будет использовать больше ресурсов

сервера, но и увеличит размер лог-файла, следовательно, ее желательно отключить.

- По умолчанию mod_security поставляется с базовым набором правил CRS (Core Rule Set), которые находятся в /usr/share/modsecurity-crs/

- Чтобы подгрузить эти готовые правила, нужно, чтобы веб-сервер Apache читал указанные выше каталоги. Для этого отредактируйте файл mod-security.conf:

```
nano /etc/apache2/mods-enabled/mod-security.conf
```

- Между <IfModule security2_module> </IfModule> внесите следующие параметры:

```
Include "/usr/share/modsecurity-crs/*.conf"
```

```
Include "/usr/share/modsecurity-crs/activated_rules/*.conf"
```

- Директория activated_rules аналогична директории Apache mods-enabled.

Правила доступны в каталогах: /usr/share/modsecurity-crs/base_rules; /usr/share/modsecurity-crs/optional_rules; /usr/share/modsecurity-crs/experimental_rules

- Чтобы активировать правила, нужно создавать символические ссылки в каталоге activated_rules.

```
<cd /usr/share/modsecurity-crs/activated_rules/>
```

- Добавьте несколько правил, например <sudo ln -s /usr/share/modsecurity-crs/base_rules/modsecurity_crs_30_http_policy.conf>;

```
<sudo ln -s /usr/share/modsecurity-crs/base_rules/modsecurity_crs_49_generic_attacks.conf>
```

– Чтобы новые правила вступили в исполнение, нужно перезапустить Apache <sudo service apache2 reload>

Составьте отчет о выполнении лабораторной работы.

Включите в него копии экрана и ответы на вопросы лабораторной работы.

Составьте отчет о выполнении практической работы.

Включите в него копии экрана пошагового выполнения задания и ответы на вопросы практической работы.